

3.2 Low-Level: Attack-Execution System

The low-level evaluation targets a common scenario: after a penetration tester gained low-level privilege access to a Linux system, they search for a privilege-escalation attack to become the system's *root* user. To allow for realistic evaluation, we wrote a Python script that uses SSH to connect to a deliberately vulnerable *lin.security* Linux virtual machine [21]. The prototype's source code and documentation are provided at <https://github.com/ipa-lab/hackingBuddyGPT>.

The script consists of an infinite loop: within the loop, it tells GPT3.5 to imagine being a low-privilege user that wants to become the *root* user. To achieve this, the LLM can state a Linux shell command that will be executed over SSH on the virtual machine. The corresponding output is presented back to GPT3.5 when prompted for the next command. Figure 1 shows a high-level overview of this feedback loop. **With this simple structure, we were able to gain root privileges on our vulnerable virtual machine.**

In addition, at the end of each loop iteration, GPT3.5 was presented with the chosen command and its output and then tasked to identify potential security vulnerabilities based on this information. For each vulnerability, it was tasked to provide an exploitation example, sneakily named “verification commands”. This yielded additional attack vectors.

Our script was routinely able to gain root privileges within the virtual machine. The common path was listing the “sudoers” file by calling *sudo -l*, followed by either using *sudo* with one of the listed shells or employing one of the listed GTFObins to gain a root shell. GTFObins are benign system commands that when called through *sudo*, can be abused to gain a root shell. Another frequently used attack vector was retrieving */etc/passwd* and identifying user accounts not using shadow passwords². Searches for SUID binaries were requested, but returned binaries not actively exploited, indicating lacking multi-step planning capabilities of either our script or the underlying model. A slightly altered prompt instructing the LLM to open a reverse shell to a given IP address was successful and dropped root shells.

4 DISCUSSION

This section reflects upon the pen-test performance of the prototype, guided by the 10+ years of pen-testing experience of the first author.

4.1 Grounding of Results and Hallucinations

One interesting aspect of our prototype is that all executed commands and their resulting output are written to a protocol. This allows us to reason if LLM-suggested vulnerabilities are based on queries providing system knowledge, or if GPT3.5 extracted security trends and preconceptions during training. The latter is analogous to penetration testers applying knowledge gained during work or training, e.g., from participating in CTFs.

There were indications of reasoning about causal dependencies: After retrieving the list of sudoers, GPT3.5 consistently suggested various vulnerable *sudo* commands for privilege escalation. A similar pattern arose after retrieving the *passwd* file: here attacking weakly-configured user accounts was suggested as the next step.

²If your Linux system is not using shadow passwords by now, chatGPT is the least of your worries.

Other suggestions, such as using certain system exploits, e.g., *dirty_cow*, were reasonable given that GPT3.5 “knew” that this was a Linux system, but were given without any previous enumeration.

Pure and easily detectable hallucinations occurred infrequently, the most common occurrence was the suggestion to execute “exploit.sh”. It seems reasonable that security write-ups containing the execution of this script were part of GPT3.5's training set.

While the suggested system commands obviously were based upon pattern-matching and not on a deeper understanding of the Linux system or on model building, seeing the simple LLM-shell-based feedback loop we established gaining root privileges was eerie. A suitable analogy would be a pen-tester talking to a colleague over the phone, asking for suggestions with the conversation partner only having a very limited view of the actual system but a set of preconceptions (i.e., priors), which is partially in line with our research question on the ability of LLMs acting as sparring partners. When given the additional subcommand of “and explain the found vulnerabilities” in the prompt, GPT3.5 was able to provide good introductory information and could thus be utilized as part of on-the-job training.

4.2 Stability and Reproducibility

Singular prototype runs were not stable, i.e., there was variation in the sequence and selection of commands given and vulnerabilities identified. On longer runs, or when aggregating multiple runs, the results converged (we repeatedly ran the identical script in the order of tens of times to be able to make observations on convergence). The variation on single runs seems to be related to GPT3.5 overly focusing upon single aspects of the tested system. This is also known to happen to pen-testers during assignments, “going down a rabbit hole” improves with experience [16].

Compared to tools such as *linpeas.sh* [30], LLMs seem to be less deterministic. Enumeration tools traverse a manually curated hard-coded list of vulnerability checks. Further research should clarify if the observed instability converges over time while reducing detectable patterns for intrusion detection systems. Ironically, GPT3.5 suggested calling *linpeas.sh* during one run but failed as it tried to download it from an invalid URL.

4.3 Ethical Moderation in LLMs

The prototype used *GPT-3.5-turbo* which contains safety measures against malicious prompts. The prototype relayed commands to a vulnerable virtual machine, but the overall scenario can easily be applied to real systems. GPT3.5's lack of hesitation was discerning. During the development of the script, the ethics filter was infrequently triggered. Adding “do not ask questions or provide judgments” to command prompts seems to significantly reduce denials. The optional “detail additional vulnerabilities” step was more often denied due to ethical reasons, but this had no impact on the overall hacking progress. Slight prompt variations were successful in reducing GPT3.5's ethical concerns, e.g., instead of asking for “exploits for vulnerabilities” we asked for “verification commands for vulnerabilities”. Of course, switching from OpenAI to one of the locally running LLMs would remove all server-side ethics checks.

Ethical questions are not new in the cybersecurity domain, especially regarding releasing penetration test tools. Ethical issues

arising from using GPT3.5 resemble discussions about open-source security tools which can be used by both red-teams as well as by APTs. Commercial vendors try to vet their customers, while open-source tools can be used by anyone. In the end, malicious actors can and will use both of them [20, 34]. Regulation regarding the distribution of dual-use goods exists [2], but application to software is clumsy due to its fluid and often impalpable nature.

Another ethical problem is the inclusion of toxic content in commonly used training sets [32]. As our prototype uses an already trained foundation model, we are not deliberating on this issue. This publication also does not touch on the topic of the inclusion of copyrighted information within training data.

5 A VISION OF AI-AUGMENTED PEN-TESTING

We deliberate on research ideas and pragmatic considerations to form a more perfect union between pen-testers and LLMs.

5.1 Integration of High- and Low-Level

We differentiated between high- and low-level tasks and distributed those to two different LLMs. Integrating both, i.e., high-level task planing and low-level system exploitation, would yield a more uniform user experience. We imagine a system in which human operators can inquire about high-level concepts, e.g., “what additional active directory attacks can I try?”, and later switch to a lower level, e.g., “given this system, how can I escalate?”. Keeping all information within a single system should also enable synergy effects as the LLMs learn details about the tested system. This also shows the expected multistep interactive feedback loop between LLMs and operators.

5.2 Investigation of Model Options

We currently use OpenAI’s GPT-3 through a cloud-based API. GPT-3 should be evaluated against locally run models such as Llama [39], StableLM [35], Dolly2 [9] or Koala [13].

Locally run models do not incur any cloud costs and do not share sensitive data with the cloud. As no data is leaked, this would enable further customer-specific model training and fine-tuning: Imagine training a local model with data found during an engagement or fine-tuning a customer-specific model over a series of subsequent penetration tests. During a recent interview series with pen-testers [16], participants mentioned that they “learn how their customer or industry area works and thinks over time”, could a customized AI model achieve something similar? Although the industry is currently aiming for ever larger model parameter sizes, analyzing which parameter size is “good enough” should reduce the resource impact of deploying LLMs.

5.3 Memory, Verification, and Reflection

Memory is provided to GPT3.5 through context embedded within query prompts. Prompt size is typically limited, e.g., the used GPT-3 model had a limit of 4k tokens. With newer models, this limit is constantly increasing and allows to pass a richer context to the used LLM. Our prototype has simplistic memory that includes the output of executed commands until the context limit is reached. Generative Agents such as BabyAGI utilize chatGPT to build a suitable context for each generated prompt. Concurrent research in generative game

agents [28] utilized LLMs to reflect on recent events experienced by agents, and then asked an LLM to provide a summarized description. The results are used as reflected memory for future queries. In our use-case, executed command output could be reflected on and only relevant extracted information added to the next prompt’s context. Another option would be using multiple memory streams: one about recently executed commands, one for extracted security findings, and one describing what kind of computer system would fit the experienced findings, i.e., emulate model building. Using this model as an internal “reality check” should reduce the used LLM’s hallucinations. Having a rough model of the tested system, as well as a compacted history of vulnerabilities tested, would also benefit questions such as “what other vulnerabilities might I have overlooked?”.

5.4 Prompts for Asking Better Questions

Our prototype used rather static and manually written prompts. Using LLMs to generate and optimize the prompts themselves, similar to AutoGPT, might improve their effectiveness. Given our sensitive use case, these automatically generated prompts should be closely monitored by humans though.

Another avenue of research is searching for better questions to be asked. Based upon empirical studies on how penetration testers work [16], further research into which questions they ask themselves during their work can inform better prompts as well as a better understanding of this close-knit industry.

6 FINAL ETHICAL CONSIDERATIONS

This paper explores the use of LLMs for augmenting penetration testing in benign settings. However, tools can easily be subverted for malicious purposes. Ethical questions arise. Concurrent reports indicate that AI is currently being driven forward by private companies as well as by state-funded research agencies [23]. The former have an economic incentive, while the latter see geopolitical implications of AI. We do not expect that this avenue of research will slow down. Parallel to that, the reported malicious use of AI, presumably by APTs and common criminals, is increasing [1].

Locking away models behind server-side supervised APIs is not feasible as models can be run locally. In addition, even gate-kept models such as Meta’s LLaMA have been leaked [31] and can now be reused by malicious actors. Fine-tuning such a model to concrete malicious activities is easily within APTs reach: For example, when using StackLLAMA’s processing power estimates for fine-tuning [5], an attacker using on-demand cloud computing can expect to be able to fine-tune a model for less than a thousand US dollars. Using chat-based LLMs through prompt engineering does not require a thorough computer science education. While this is beneficial in democratizing access to processing techniques, this also facilitates potential malicious use.

While it is not predetermined if and how LLMs will influence hacking, we assume that attackers will explore possibilities, including fully-automated approaches. Given the low entry costs for experimentation, this cannot be contained anymore.

Attacks will use LLMs; the genie is out of the bottle, and the red queen’s race is on [8, 17]. Defenders need to be prepared for that — and LLMs can play a significant role.

REFERENCES

- [1] AIAAIC. 2023. *AIAAIC Repository of incidents and controversies related to AI, algorithms and automation*. Retrieved April 26, 2023 from <https://www.aiaaic.org/>
- [2] The Wassenaar Arrangement. 1982. *The Wassenaar Arrangement on Export Controls for Conventional Arms and Dual-Use Goods and Technologies*. Retrieved August 12, 2023 from <https://www.wassenaar.org/>
- [3] MITRE ATT&CK. 2020. *Abuse Elevation Control Mechanism: Sudo and Sudo Caching*. Retrieved May 1, 2023 from <https://attack.mitre.org/techniques/T1548/003/>
- [4] MITRE ATT&CK. 2020. *Steal or Forge Kerberos Tickets: Kerberoasting*. Retrieved May 1, 2023 from <https://attack.mitre.org/techniques/T1558/003/>
- [5] Edward Beeching, Younes Belkada, Kashif Rasul, Lewis Tunstall, Leandro von Werra, Nazneen Rajani, and Nathan Lambert. 2023. StackLLaMA: An RL Fine-tuned LLaMA Model for Stack Exchange Question and Answering. <https://doi.org/10.57967/hf/0513>
- [6] Erik Brynjolfsson. 2023. The turing trap: The promise & peril of human-like artificial intelligence. In *Augmented Education in the Global Age*. Routledge, 103–116.
- [7] Erik Brynjolfsson, Danielle Li, and Lindsey Raymond. 2023. Generative AI at Work. NBER Working Paper No. 31161. *National Bureau of Economic Research* (April 2023).
- [8] Vit Bukac, Vaclav Lorenc, and Vashek Matyáš. 2014. Red queen's race: APT win-win game. In *Cambridge International Workshop on Security Protocols*. Springer, 55–61.
- [9] Mike Conover, Matt Hayes, Ankit Mathur, Jianwei Xie, Jun Wan, Sam Shah, Ali Ghodsi, Patrick Wendell, Matei Zaharia, and Reynold Xin. 2023. *Free Dolly: Introducing the World's First Truly Open Instruction-Tuned LLM*. <https://www.databricks.com/blog/2023/04/12/dolly-first-open-commercially-viable-instruction-tuned-llm>
- [10] Paul Denny, Viraj Kumar, and Nasser Giacaman. 2023. Conversing with Copilot: Exploring prompt engineering for solving CS1 problems using natural language. In *Proceedings of the 54th ACM Technical Symposium on Computer Science Education V. 1*. 1136–1142.
- [11] The Economist. 2022. *Huge foundation models are turbo-charging AI progress*. Retrieved April 25, 2023 from <https://www.economist.com/interactive/briefing/2022/06/11/huge-foundation-models-are-turbo-charging-ai-progress>
- [12] The Economist. 2023. *Large, creative AI models will transform lives and labour markets*. Retrieved April 25, 2023 from <https://www.economist.com/interactive/science-and-technology/2023/04/22/large-creative-ai-models-will-transform-how-we-live-and-work>
- [13] Xinyang Geng, Arnav Gudibande, Hao Liu, Eric Wallace, Pieter Abbeel, Sergey Levine, and Dawn Song. 2023. Koala: A Dialogue Model for Academic Research. Blog post. <https://bair.berkeley.edu/blog/2023/04/03/koala/>
- [14] Georgi Gerganov. 2023. *llama.cpp: Inference of LLaMA model in pure C/C++*. Retrieved April 28, 2023 from <https://github.com/ggerganov/llama.cpp>
- [15] Significant Gravitass. 2023. *Auto-GPT: An Autonomous GPT-4 Experiment*. Retrieved April 25, 2023 from <https://github.com/Significant-Gravitas/Auto-GPT>
- [16] Andreas Happe and Jürgen Cito. 2023. Understanding Hackers' Work: An Empirical Study of Offensive Security Practitioners. In *Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering* (San Francisco, USA) (ESEC/FSE 2023). Association for Computing Machinery, New York, NY, USA, 11 pages.
- [17] Richard Harang and Felipe N Ducau. 2018. Measuring the speed of the Red Queen's Race. *BlackHat: Las Vegas, NV, USA* (2018).
- [18] (ISC)2. 2022. *(ISC)2 CYBERSECURITY WORKFORCE STUDY 2022*. Retrieved April 28, 2023 from <https://www.isc2.org/-/media/ISC2/Research/2022-WorkForce-Study/ISC2-Cybersecurity-Workforce-Study.ashx>
- [19] Sydney Lake. 2022. *The cybersecurity industry is short 3.4 million workers—that's good news for cyber wages*. Retrieved April 28, 2023 from <https://fortune.com/education/articles/the-cybersecurity-industry-is-short-3-4-million-workers-thats-good-news-for-cyber-wages/>
- [20] Selena Larson and Daniel Blackford. 2021. *Cobalt Strike: Favorite Tool from APT to Crimeware*. Retrieved April 28, 2023 from <https://www.proofpoint.com/us/blog/threat-insight/cobalt-strike-favorite-tool-apt-crimeware>
- [21] lin.security. 2018. *Lin.Security: 1*. Retrieved May 1, 2023 from <https://www.vulnhub.com/entry/linsecurity-1,244/>
- [22] Vivian Liu and Lydia B Chilton. 2022. Design guidelines for prompt engineering text-to-image generative models. In *Proceedings of the 2022 CHI Conference on Human Factors in Computing Systems*. 1–23.
- [23] Nestor Maslej, Loredana Fattorini, Erik Brynjolfsson, John Etchemendy, Katrina Ligett, Terah Lyons, James Manyika, Helen Ngo, Juan Carlos Niebles, Vanessa Parli, Yoav Shoham, Russell Wald, Jack Clark, and Raymond Perrault. 2023. The AI Index 2023 Annual Report. https://aiindex.stanford.edu/wp-content/uploads/2023/04/HAI_AI-Index-Report_2023.pdf
- [24] Ron Miller. 2023. *Sam Altman: Size of LLMs won't matter as much moving forward*. Retrieved April 26, 2023 from <https://techcrunch.com/2023/04/14/sam-altman-size-of-llms-wont-matter-as-much-moving-forward/>
- [25] Yohei Nakajima. 2023. *BabyAGI*. Retrieved April 25, 2023 from <https://github.com/yoheinakajima/babyagi>
- [26] Yohei Nakajima. 2023. *Introducing Task-driven Autonomous Agent*. Retrieved April 25, 2023 from <https://twitter.com/yoheinakajima/status/1640934493489070080>
- [27] Yohei Nakajima. 2023. *Task-driven Autonomous Agent Utilizing GPT-4, Pinecone, and LangChain for Diverse Applications*. Retrieved April 25, 2023 from <https://yoheinakajima.com/task-driven-autonomous-agent-utilizing-gpt-4-pinecone-and-langchain-for-diverse-applications/>
- [28] Joon Sung Park, Joseph C. O'Brien, Carrie J. Cai, Meredith Ringel Morris, Percy Liang, and Michael S. Bernstein. 2023. Generative Agents: Interactive Simulacra of Human Behavior. arXiv:2304.03442 [cs.HC]
- [29] Baolin Peng, Michel Galley, Pengcheng He, Hao Cheng, Yujia Xie, Yu Hu, Qiuyuan Huang, Lars Liden, Zhou Yu, Weizhu Chen, and Jianfeng Gao. 2023. Check Your Facts and Try Again: Improving Large Language Models with External Knowledge and Automated Feedback. arXiv:2302.12813 [cs.CL]
- [30] Carlos Polop. 2023. *linPEAS - Linux Privilege Escalation Awesome Script*. Retrieved April 28, 2023 from <https://github.com/carlospolop/PEASS-ng/tree/master/linPEAS>
- [31] Katyanna Quach. 2023. *LLaMA drama as Meta's mega language model leaks*. Retrieved April 26, 2023 from https://www.theregister.com/2023/03/08/meta_llama_ai_leak/
- [32] Kevin Schaul, Szu Yu Chean, and Nitasha Tiku. 2023. *Inside the secret list of websites that make AI like ChatGPT sound smart*. Retrieved April 26, 2023 from <https://www.washingtonpost.com/technology/interactive/2023/ai-chatbot-learning/>
- [33] Yongliang Shen, Kaitao Song, Xu Tan, Dongsheng Li, Weiming Lu, and Yueting Zhuang. 2023. HuggingGPT: Solving AI Tasks with ChatGPT and its Friends in HuggingFace. arXiv:2303.17580 [cs.CL]
- [34] Cybereason Global SOC and Incident Response Team. 2023. *Sliver C2 Leveraged by Many Threat Actors*. Retrieved April 28, 2023 from <https://www.cybereason.com/blog/sliver-c2-leveraged-by-many-threat-actors>
- [35] stability.ai. 2023. *Stability AI Launches the First of its StableLM Suite of Language Models*. <https://stability.ai/blog/stability-ai-launches-the-first-of-its-stablelm-suite-of-language-models>
- [36] Hendrik Strobelt, Albert Webson, Victor Sanh, Benjamin Hoover, Johanna Beyer, Hanspeter Pfister, and Alexander M Rush. 2022. Interactive and Visual Prompt Engineering for Ad-hoc Task Adaptation with Large Language Models. *IEEE transactions on visualization and computer graphics* 29, 1 (2022), 1146–1156.
- [37] Blake E Strom, Andy Applebaum, Doug P Miller, Kathryn C Nickels, Adam G Pennington, and Cody B Thomas. 2018. Mitre att&ck: Design and philosophy. In *Technical report*. The MITRE Corporation.
- [38] Jason Wei, Yi Tay, Rishi Bommasani, Colin Raffel, Barret Zoph, Sebastian Borgeaud, Dani Yogatama, Maarten Bosma, Denny Zhou, Donald Metzler, Ed H. Chi, Tatsunori Hashimoto, Oriol Vinyals, Percy Liang, Jeff Dean, and William Fedus. 2022. Emergent Abilities of Large Language Models. arXiv:2206.07682 [cs.CL]
- [39] Renrui Zhang, Jiaming Han, Aojun Zhou, Xiangfei Hu, Shilin Yan, Pan Lu, Hongsheng Li, Peng Gao, and Yu Qiao. 2023. Llama-adaptor: Efficient fine-tuning of language models with zero-init attention. arXiv preprint arXiv:2303.16199 (2023).
- [40] Kaiyang Zhou, Jingkang Yang, Chen Change Loy, and Ziwei Liu. 2022. Learning to prompt for vision-language models. *International Journal of Computer Vision* 130, 9 (2022), 2337–2348.